1 Muss ich wissen – Grundlagen

Security Engineering: Definition und Abgrenzung F5–7; T1:41–4:53 **?F77**

- **Security Engineering** baut Systeme, die trotz **malice, error and mischance** dependable bleiben, mit Tools, Prozessen und Methoden für design, implement, test und Anpassung an eine veränderte Umgebung.
- **Security vs. Safety**: Bei Security ist meist ein **Threat Actor** beteiligt, ohne Angreifer geht es um Safety.
- **Software Engineering** sorgt dafür, dass bestimmte Dinge passieren („John can read this file"), Security ist aber nicht bloß das Verhindern von Dingen, weil die Realität komplexer ist.
- **Security Requirements** sind systemabhängig und meist eine Kombination aus user authentication, transaction integrity, accountability, fault-tolerance und message secrecy.
- **Adversarial Thinking** heißt, frühere Angriffe, Entry Paths, Entwicklungen und Outcomes zu studieren.

Disziplinen und warum Systeme scheitern F6,8,16; T2:21–3:07,5:04,6:14 **?F79**

- **Cross-disciplinary expertise**: Business Processes, Software Engineering und Testing, Cryptography und Computer Security bis Hardware Tamper-Resistance sowie Economics, Applied Psychology, Organizations und Law.
- **Hauptgrund für Fehlschläge**: Designer schützen die falschen Dinge oder die richtigen Dinge auf die falsche Weise.
- **Zu enge Systemgrenze**: Als sicher beworbene Systeme brachen, sobald eine bestimmte Application lief oder das Gerät anders als vorgesehen genutzt wurde.
- **Human Components ignorieren** und damit Usability vernachlässigen ist laut F16 eine der größten Ursachen für Security Failure.
- **Falsche Incentives**: Wer das System bewacht und wartet, muss geschult und richtig motiviert sein, sonst werden die Schutzziele verfehlt.

System: sechs Definitionen – im Kurs gilt Definition 6 F16; T13:08–15:13 **?F77**

- **1** = Produkt oder Komponente wie ein kryptografisches Protokoll, eine Smartcard oder die Hardware von Phone, Laptop oder Server.
- **2** = 1 plus Operating System, Communications und weitere Infrastruktur; **3** = plus Applications (Banking-App, Browser, LLM . . . , Client- und Cloud-Teile).
- **4** = plus IT Staff; **5** = plus interne Users und Management; **6** = plus Customers und andere externe Users.
- **Merksatz Vorlesung**: Krypto-Leute denken meist an 1–2, Firmen hören bei 5 auf, wir nehmen alle sechs Stufen.

Workflow: vier Schritte in dieser Reihenfolge F10–13,32; T7:19–12:58 **?F77**

- **1. Threat Model**: Wer könnte warum und wie angreifen – Insider oder Outsider, People oder Malware, Government, Crooks oder Script Kiddy?
- **2. Security Policy**: Welche Protection Properties sollen gelten (Keep secret? Guard money?) und welche Regeln brauchen wir?
- **3. Implementation**: Welche Protection Mechanisms setzen wir ein und warum?
- **4. Assurance**: Woher wissen wir, dass wir genug getan haben, und wie beweisen wir das Dritten?
- **Assurance ≠ Compliance**: Compliance ist nur das Zertifikat (z. B. Common Criteria, ISO 27000), Assurance stellt die Zielerreichung wirklich sicher und weist sie Dritten nach.

Threat Model: warum wichtig? F33; T7:46–8:55,40:31–41:10 **?F77**

- **Likely Threat Actors** zuerst identifizieren, jeweils mit ihren **Incentives/Goals** und **Capabilities/Knowledge**.
- **Kein Totalschutz**: Gegen alle denkbaren Threats schützen und trotzdem nützliche Arbeit zu reasonable cost leisten geht nicht, also priorisiert man die dringendsten Threat Actors.
- **Kontext entscheidet**: Ein Chiphersteller wie Infineon fürchtet eher Nation-State Actors und Konkurrenz, Payment/Banking eher Cyberkriminelle mit monetären Incentives.
- **Insider Threats** sind Menschen, deren Incentives nicht mehr zur Firma passen, und laut Vorlesung auch Malware.

Security Engineering Analysis Framework (Figure 1.1) F9,14; T6:55–7:07,12:19–12:58

- **Policy** = was das System erreichen soll, **Mechanism** = die technischen Mittel wie Ciphers und Cryptography.
- **Assurance** = wie viel Verlass auf die Mechanismen besteht, **Incentives** = die Motive derer, die das System bewachen oder angreifen.
- **Alle vier Kästen sind miteinander verbunden** und beeinflussen sich gegenseitig.

1 Muss ich wissen – Definitionen

Person, Subject, Principal F17–18; T15:18–18:14 **?F78**

- **Person** = physical person oder legal person wie eine Firma oder eine Regierung.
- **Subject** = physical person in irgendeiner Rolle, z. B. Operator, Principal oder Victim, also nie eine Firma.
- **Principal** = Entität, die authentifiziert werden kann und in einem Security System handelt, z. B. Subject, Person, Role oder Equipment wie Laptop, Phone, Smartcard oder Communication Channel (Port-Nr.).
- **Zusammengesetzte Principals**: Group (Alice or Bob), Conjunction (Alice and Bob acting together), Compound Role (Alice acting as Bob's manager) und Delegation (Bob acting for Alice in her absence).

- **Alice-und-Bob-Konvention** ist ungenau: Wer ist bei „Alice authenticates herself to Bob“ gemeint, Mensch, Key oder Software?

Group vs. Role und Levels of Abstraction F19; T18:14–19:44 **?F78**

- **Group** = Menge von Principals, etwa alle Studierenden im Hörsaal.
- **Role** = Menge von Funktionen, die nacheinander von verschiedenen Personen übernommen werden, etwa „the rector of AAU“ oder „student“.
- **Levels of Abstraction**: „Bob's smartcard representing Bob who is acting for Alice“ ist etwas anderes als „Bob operating Alice's smartcard in her absence“.
- **Regel**: präzise beschreiben und das Abstraction Level ausdrücklich angeben.

Identity, Trust, Trustworthiness F20–21; T19:44–22:08 **?F77**

- **Identity** = Correspondence zwischen den Namen zweier Principals, die anzeigt, dass beide dieselbe Person oder dasselbe Equipment meinen, also kein bloßer Name.
- **Beispiel**: Bob in „Bob acting for Alice in her absence“ ist derselbe Bob wie in „Bob acting as Charlie's manager“.
- **Trusted** = System oder Komponente, deren Versagen die Security Policy brechen kann, z. B. das TPM im Computer.
- **Trustworthy** = System oder Komponente, die nicht versagt.
- **Trusted but not trustworthy**: ein NSA-Mitarbeiter, der unautorisiert Key Material an einen chinesischen Diplomaten verkauft.

Confidentiality, Privacy, Anonymity F22–23; T22:29–26:08 **?F78**

- **Confidentiality (non-disclosure)** = Verpflichtung, Geheimnisse einer anderen Person oder Organisation zu schützen, wenn man sie kennt.
- **Privacy** = Fähigkeit und/oder Recht, die eigenen persönlichen Informationen zu schützen, erweitert auf das Verhindern von Eingriffen in den persönlichen Raum.
- **Merksatz (Secrecy = Preventing Information Sharing)**: Privacy ist Secrecy zum Nutzen des Individuums, Confidentiality zum Nutzen der Organisation (Patient = Privacy, Pflicht des Arztes = Confidentiality).
- **Anonymity** = lack of attribution einer Person zu einer von ihr begangenen Tat, bis hin zu bewusster Geheimhaltung.
- **Internet nicht für Anonymity entworfen**: Protokolle und IP-Adressen verraten Metadaten, die leichter zu bekommen sind als Inhalte, und anonym ist man nur in einer Crowd to hide in.

Integrity, Authenticity, Availability, Security Failure F24; T26:42–28:09 **?F78**

- **Integrity** = Zusicherung, dass Daten nicht verändert wurden, das Gegenteil von Data Corruption (at move/rest).
- **Authenticity** = Integrity **plus Freshness plus Proof of Identity**: Man spricht nachweislich mit einem genuine Principal und nicht mit einem Replay alter Nachrichten.
- **Freshness-Beispiel**: Zertifikate für digitale Signaturen gelten nur eine bestimmte Zeit.
- **Availability** = Daten und Netzwerkressourcen sind für autorisierte Nutzer bei Bedarf zugänglich.
- **Security Failure** = unerwünschte Verletzung der Security Policy eines Systems.

Weakness, Vulnerability, Exploit, CWE/CVE F25–26; T29:03–32:51 **?F78**

- **Weakness** = Bedingung in einer SW/HW-Komponente, die zur Entstehung von Vulnerabilities beitragen könnte.
- **Vulnerability** = Schwäche eines Systems oder seiner Umgebung, die zusammen mit einer internen oder externen Threat zu einem Security Failure führen kann.
- **Exploit** = Methode oder Code, der eine Vulnerability ausnutzt.
- **CWE** listet Weakness-Typen, z. B. **CWE-125 Out-of-bounds Read**: Das Produkt liest hinter dem Ende oder vor dem Anfang des vorgesehenen Buffers.
- **CVE** listet konkrete Vulnerabilities, z. B. **CVE-2014-0160 Heartbleed** in der OpenSSL Library: improper input validation (missing bounds check) in der TLS Heartbeat Extension.

Threat, Threat Actor, Hack F25,27; T28:24–29:03,32:51–33:45 **?F79**

- **Threat** = Handlung oder Ereignis, das zu einer unerwünschten negativen Wirkung auf ein Computersystem führen würde (Security Failure).
- **Threat Actor** = Person, Gruppe, Organisation, Staat oder andere Entität mit der Fähigkeit, eine Threat zu cause, carry, transmit, support oder exploit.
- **Zusammenspiel**: Ein Threat Agent nutzt per Exploit eine Vulnerability aus, dazwischen liegen Countermeasures.
- **Hack nach Bruce Schneier** = etwas, das die Regeln eines Systems erlauben, das aber von seinen Designern weder vorhergesehen noch gewollt war.

Security Policy, Security Target, Protection Profile, Protection F29–30; T35:53–39:32 **?F79**

- **Security Policy (what)** = knappe Aussage der Schutzstrategie eines Systems in Business Goals, z. B. „in jeder Transaction sind Credits und Debits gleich, und alles über $1.000.000 müssen zwei Manager autorisieren“.
- **Security Target/Goal (how)** = detailliertere Spezifikation (keine Implementation), wie die Policy in einem bestimmten Produkt umgesetzt wird (Encryption, Digital Signatures, Access Controls, Audit Logs), und Maßstab für die Implementation.

- **Protection Profile** = Interface zwischen Security Target und Security Policy: wie ein Security Goal, aber device-independent genug für vergleichende Evaluations verschiedener Produkte und Versionen.
- **Protection** = abstrakte Eigenschaft wie Confidentiality oder Integrity, abstrakt genug für allgemeine Systeme statt konkreter Implementierungen.
- **Hierarchie** (abstrakt → konkret): Protection → Protection Profile → Security Target → Implementation.

1 Muss ich wissen – Adversaries

Wer sind die Gegner und was treibt sie an?

F34,61–62,67,75; T9:08–9:28,41:41–42:37 **?F80 ?F82**

- **State Actors** (Five Eyes, China, Russia, Iran, North Korea . . .) wollen den **Intelligence Contest** gewinnen, also Informations- und Machtvorteile.
- **Crooks** sind Kriminelle mit **economic incentives**, z. B. Ransomware-Gangs und Fraudsters, von kleinem Betrug bis zu großen Cryptocurrency Hacks.
- **The Swamp** sind Kriminelle mit **abuse incentives**, z. B. Hate Crimes, Abuse und Bullying.
- **Lawful Operators** wie Security Researchers und Tool Vendors kommen nächstes Mal, **Hacktivism und Script Kiddies** werden nicht behandelt.
- **„The rest of us“**: Wir alle können in verschiedenen Rollen unwissentlich als Amplifier für schädliches Material wirken.

Intelligence Contests (Intelligence Doctrine)

F61; T1:23:10–1:23:50 **?F81**

- **Quelle**: Joshua Rovner, früher scholar-in-residence der NSA.
- **1. Collect, 2. Exploit**: Rennen, mehr und bessere Informationen als der Gegner zu sammeln und damit die eigene Position zu verbessern.
- **3. Undermine**: wechselseitiger Versuch, Moral, Institutionen und Allianzen des Gegners zu untergraben.
- **4. Disable, 5. Preposition**: gegnerische Fähigkeiten durch Sabotage ausschalten und Assets für den Konfliktfall vorpositionieren.
- **Merksatz**: Intelligence Contests werden nie wirklich gewonnen oder verloren.

Five Eyes (FVEY): wer und wie?

F36–37,45; T43:05–46:08,56:53–58:19,1:00:50 **?F80**

- **Mitglieder**: USA, UK, Canada, Australia und New Zealand teilen Intelligence-Infrastruktur.
- **Platform Advantage**: Viele Glasfasern folgen alten Telegraph-/Telefonkabeln (Commonwealth-Routen), daher bulk wiretap u. a. in Cornwall, Gibraltar, Malta und Singapore.
- **Weitere Quellen**: Satellite Downlinks und Embassies, und SIGINT-Agencies (NSA, GCHQ) bekommen mehr Geld als klassisches Human Spying.
- **Crypto Wars**: Die Agencies wollten starke Kryptografie untergraben, z. B. mit dodgy RNGs und sabotierten Protokollstandards, um VPN-Traffic zu entschlüsseln.
- **2013 Edward Snowden** enthüllte das Ausmaß, laut Vorlesung als Whistleblower ein Insider Threat, der Confidentiality brach.

PRISM, TEMPORA, XKEYSCORE

F38–40,46–47; T47:22–51:34,58:58–1:00:32 **?F81**

- **PRISM** = Zugriff auf die Server von Providern wie Microsoft, Google, Yahoo, Facebook, YouTube, Skype, AOL und Apple, genannt **downstream collection** („Never mind the key, get the server“).
- **Warrant**: Für US citizens braucht es probable cause (FBI), Foreigners (alle anderen, NSA/CIA) haben laut Vorlesung diesen Schutz nicht.
- **TEMPORA** = großflächiger Zugriff auf Optical Fibers an Dutzenden Orten (**upstream collection**), dazu Computer Network Exploitation (bulk und targeted Hacking).
- **XKEYSCORE** = verteilte Search Engine über ca. 100 Repositories weltweit für Anfragen wie „show me everybody in Afghanistan who's communicating in German“.
- **Routing**: Traffic nimmt den cheapest, nicht den physisch direktesten Pfad, deshalb fließt viel Kommunikation durch die USA.

Five Eyes: zwei Fallbeispiele

F42–44; T51:34–56:34

- **Google (Leaked Slide)**: SSL lief nur bis zum Google Front End (GFE), zwischen den Data Centers floss der Traffic im Klartext, weshalb Google danach auch diesen Verkehr verschlüsselte.
- **Operation Socialist (2010–13)**: GCHQ hackte Belgacom, um Telefone in Belgien (EU) im industriellen Maßstab abzuhören, also EU-Officials und Telefonverkehr nach Afrika.
- **Vorgehen laut Vorlesung**: Malware bei Belgacom-Technikern, Lateral Movement bis zum GRX-Roaming-Proxy und dann Man-in-the-Middle auf den Mobilfunkverkehr.

China: Hacks

F48–52; T1:01:16–1:08:54 **?F81 ?F83**

- **Strategic Peer Competitor** der USA, dessen Hacking sich von smart people mit simple tools (2000er) zu systematischen Operationen im industriellen Maßstab entwickelte.
- **Hacks**: Dalai Lama (2008), Google (2009), Office of Personnel Management (OPM, 2015) und Microsoft (2021).
- **Dalai Lama (2008)**: Spear-Phishing eines Mönchs in Dharamsala, dann Malware auf dem Mailserver, die PDF-Anhängen einen JavaScript Buffer Overflow einfügte und 35 der 50 PCs der Exilregierung übernahm.

- **Google (2009)**: China hackte genau die Einrichtung, die Google für den warranted access von NSA/FBI bauen musste, um herauszufinden, welche eigenen Agenten in den USA dem FBI bekannt waren.
- **OPM (2015)**: China stahl die Datenbank der Security Clearances mit allen Antworten auf intrusive Fragen, die zur Erpressung taugen („database of ruin“).

China: Belt and Road und Platform Advantage F49,53; T1:09:10–1:11:47 **?F81**

- **Belt and Road Initiative**: China hilft Entwicklungsländern beim Ausbau von Infrastruktur inklusive Telekommunikation (z. B. Huawei), die dann von China kontrolliert wird.
- **Ziel**: einen eigenen Platform Advantage wie den der Five Eyes aufbauen, vor allem in Ländern, die nicht mit den USA verbündet sind.
- **Scale Access** über Belt and Road, Huawei, ZTE, TikTok und AI (z.AI; Alibaba Cloud + Qwen).
- **Full-stack competition**: Chips, Offshoring der Fertigung von US-Firmen und eigene Tech-Majors.

Russia, Iran, North Korea F54–57; T1:11:47–1:16:39 **?F81 ?F83**

- **Kein Platform Advantage** → diese Staaten setzen auf Spear-Phishing, Hacking und Information Warfare.
- **Iran**: Die Uran-Anreicherungszentrifugen wurden 2008–09 von USA & Israel gehackt (Stuxnet), worauf Iran sich an den Saudis rächte.
- **North Korea – Sony Hack (2014)**: Reaktion auf den Film *The Interview*, bei der interne Daten und E-Mails veröffentlicht wurden, laut Vorlesung eine Machtdemonstration.
- **North Korea sonst**: Hauptziel ist laut Vorlesung das Stehlen von Cryptocurrencies.
- **Russia**: Cyber-Warfare in regionalen Konflikten (Ukraine) und Einflussnahme auf Wahlen (US 2016, Romania 2025).

Stuxnet: wie es funktionierte F55–56; T1:13:08–1:15:12 **?F81 ?F83**

- **1. Infection, 2. Search**: Eintritt per USB-Stick in Windows-Rechner, getarnt durch ein digitales Zertifikat, dann Suche nach dem Siemens Industrial Control System der Zentrifugen.
- **3. Update**: Ist der Rechner kein Ziel, tut Stuxnet nichts, sonst lädt der Worm neuere Versionen von sich nach.
- **4. Compromise, 5. Control**: Zero-Day-Vulnerabilities übernehmen die PLCs (Logic Controllers), Stuxnet spioniert zuerst und lässt dann die Zentrifugen bis zum Versagen drehen.
- **6. Deceive and destroy**: Falsches Feedback an die Kontrolleure verhindert, dass jemand den Schaden rechtzeitig bemerkt.
- **Bedeutung**: erste Advanced Persistent Threat gegen cyber-physische Infrastruktur (Zäsur in der OT Security) mit vielen Infektionspfaden (USB, Contractors, S7 Project Files), die das Programm um etwa zwei Jahre zurückwarf.

Russia: Ukraine, SolarWinds, US-Wahl 2016 F54,58–60; T1:16:39–1:22:28 **?F81**

- **Ukraine Power Grid (2015)**: Start über ein präpariertes Word-Dokument, rund eine Viertelmillion Menschen stundenlang ohne Strom und gleichzeitig DoS auf die Callcenter – der erste große Blackout durch Hacker.
- **NotPetya (2017)** sollte ukrainische Firmen treffen und breitete sich bis nach Europa aus, weitere Folienbeispiele sind 2014 Vote-Counting System, 2022 WhisperGate Ransomware und Angriffe auf Military/Government HQ.
- **SolarWinds (2020)**: Supply-Chain Attack, bei dem Schadcode in eine DLL (SolarWinds.Orion.Core.BusinessLayer.dll) legitimer Software kam und mit ihr an die Kunden verteilt wurde.
- **SolarWinds-Backdoor**: prüft die Umgebung (Defense Evasion), sammelt Infos, verbindet sich mit Command-and-Control, exfiltriert Daten und erlaubt Hands-on-Keyboard-Angriffe wie Credential Theft und Lateral Movement.
- **US-Wahl 2016**: Russische Intelligence Officers hackten E-Mail-Konten der Clinton-Kampagne und das DNC, veröffentlichten das Material über Online-Personas und WikiLeaks und nutzten Troll Farms pro Trump.

Crooks: Cybercrime Ecosystem F62–64; T1:23:50–1:24:45 **?F80 ?F82 ?F83**

- **Größenordnung**: UK 2019 rund 1 Million Property Crimes, aber etwa 2,5 Millionen Online-Frauds und Scams, weil Kleinkriminalität ins Netz wanderte.
- **Ecosystem** aus Bulk Attackers, Targeted Attackers, Tool Providers und Cashout Gangs, wobei Money Mules Geld über Konten schieben, bis es nicht mehr rückverfolgbar ist.
- **Criminal Infrastructure**: unregulierte Cryptocurrency Exchanges und Botnets.
- **Summary**: seit ca. 2005 über Underground Forums organisiert, dominiert Property Crime (keine Nähe nötig, skaliert leichter) und ist international und spezialisiert.
- **Seit 2020**: Ransomware ist der große Wachstumsbereich.

Ransomware: Entwicklung F65–66 **?F82 ?F83**

- **Ransomware** = Malware, die die persönlichen Daten des Opfers verschlüsselt, bis ein Lösegeld gezahlt wird.
- **Early Days**: einfache PC-Verschlüsselung als Bulk Attack (petty crime) auf Privatnutzer, Lösegeld um 1 Bitcoin (≈ 300 GBP).
- **Current Landscape**: ausgefeilte large-scale Attacks auf große Firmen und verwundbare Institutionen, Lösegeld von Hunderttausenden bis Millionen.
- **Cryptocurrencies** sind schwer rückverfolgbar und damit vom aufkommenden Zahlungsmittel zum Critical Enabler der Ransomware-Ökonomie geworden.

The Swamp: Motiv Abuse F67–71; T9:08–9:17 **?F80**

- **Terrorism Recruitment** und **Child Sex Abuse Material (CSAM)**.
- **Hate Campaigns**, z. B. #GamerGate über 4chan, Reddit, YouTube und 8chan, teils auch Hacktivism.
- **Intimate Relationship Abuse**.
- **School/Workplace Bullying**, Folienbeispiel: Facebook Leaks (2021, Frances Haugen).

Social Media und Content Moderation F72 **?F82**

- **Nutzer**: Laut einer Oxford/TUM-Studie (2025) wollen die meisten Menschen mehr Moderation (79 %).
- **Governments** erhöhen den Druck zu zensieren bzw. zu moderieren, z. B. EU Digital Services Act und UK Online Harms Bill.
- **Tech Companies** filterten schon viel zu hohen Kosten (Sex Abuse, Terror, Hate Speech, Nudity), als Backlash hörten manche wieder auf (Twitter/X, Facebook), und AI ist ein double-edged sword.
- **Like/Share** führte zu performative Shaming, Social Media wirkt als Outrage Machine mit Folgen für die Mental Health.
- **Solutions** sind teils technisch, teils politisch und teils eine Frage sich entwickelnder sozialer Normen.

AI-Agents: Tool or Actor? F73–74 **?F83**

- **Kernfrage**: Ist ein AI-Agent Adversary oder Tool, also hat agentic AI Moral Agency oder ist sie nur eine Verlängerung menschlicher Absicht (Virtue Ethics, Moral Agency Theory)?
- **Traditional Philosophy** sagt nein und behandelt Tools als value-neutral.
- **Conditions for moral responsibility**: Freedom (Handeln ohne Zwang) und Epistemic Competence (Absichten und Folgen verstehen).
- **Complicated Supply Chains** verschleiern die Accountability im Ecosystem und erzeugen potenziell distributed moral actions.
- **Safety vs. Security**: Die Folie verweist auf diese Unterscheidung aus Systemsicherheit.

Querschnittsfrage: Online Threats erkennen und bekämpfen aus F33,64–65,72,74–75 zusammengesetzt **?F83**

- **Kein Totalschutz**: Schutz gegen alle Threats zu vertretbaren Kosten ist unmöglich, also priorisieren.
- **Verfolgung schwer**: Cryptocurrencies und ein internationales, spezialisiertes Ecosystem erschweren die Zuordnung.
- **Verteilte Verantwortung**: AI-Supply-Chains verschleiern Accountability, und wir alle wirken als Amplifier.
- **Lösungen** sind teils technisch, teils politisch und teils soziale Normen.

2 Hinweise der Lehrperson

Was kommt zum Minitest? T1:15–1:41; F76,84; M; E-Mail

- **Transkript**: „I really want to stress that you have to learn the definitions for the mini tests“ – jede Definition der Einheit kann drankommen.
- **E-Mail der Lehrperson**: Minitest am Freitag, ca. 5 Minuten, den Foliensatz *inklusive* der Fragenfolien lernen.
- **F84**: Fokus auf die Fragen am Ende des Foliensatzes, vor allem Definitionen daraus, aber das ganze Skriptum lernen; 2–3 Fragen, Multiple Choice und Fill in Text, diesmal **keine** Mathematical Computations.
- **Moodle**: Die Fragen am Foliensatzende sind relevant, aber nicht vollständig (F76: „not exhaustive“), und die Folien enthalten auch Details, die in der Vorlesung nicht besprochen wurden.
- **Abdeckung**: Jede Frage der Fragenfolien F77–F83 ist oben einem Block zugeordnet (Markierung **?F77** … **?F83** rechts im Blockkopf).

Abgrenzung und ausdrückliche Merk-Hinweise T9:28,35:07–35:37,39:32,42:26–42:37,1:18:16; F3

- **Nicht in diesem Kurs**: Attack Vectors, Tactics und Techniques (OWASP-Sicht), weil das die Definitionen sprengen würde.
- **„That's for you to know“**: die Hierarchie Protection → Protection Profile → Security Target → Implementation.
- **Hacktivism und Script Kiddies** werden nicht behandelt, Researchers und Tools kommen in der nächsten Einheit.
- **Nächste Einheit**: Security Policies und Targets mit formalen Modellen, laut F3 prüft jeder Minitest nur die vorige Einheit.
- **„I want you to remember“**: Neben dem Ukraine-Blackout gab es NotPetya, das nur ukrainische Firmen treffen sollte und sich nach Europa ausbreitete.

Logistik am Freitag F2–3,84; P9; T0:00–1:09,41:18; M

- **Termin**: Minitest in den ersten 5 Minuten der Vorlesung am 23.10.2026, also pünktlich sein (F3: „be on time“).
- **Medium unklar**: F84 und P9 sagen Moodle Quiz, F3 sagt PEN + PAPER, in Moodle ist noch kein Quiz sichtbar, also (eigene Empfehlung) Gerät mit Moodle-Login und Stift mitnehmen.
- **Wertung**: 12 Minitests à 5 Punkte, die besten 9 zählen (max. 45), bei mehr als 3 Fehlterminen oder unter 20 Punkten ersetzt das Final Exam (22.1., 11:45) die Minitests.
- **Anwesenheit**: Die Liste geht in der Mitte oder am Ende der Stunde herum, höchstens dreimal fehlen, und wer stört, fliegt raus.

- **Ältere Preamble (P9)** nannte noch 2–4 Fragen sowie True/False und Mathematical Computations, F84 ist die neuere Fassung.

Poster-Thema wählen T0:28–0:52; P11–14; M; E-Mail

- **Auftrag laut E-Mail und Vorlesung**: ein Thema wählen, in Moodle über „Task: Select Topics for Written Report/Poster Session".
- **First-come-first-served**: Die Plätze pro Thema sind begrenzt (meist 1), ein eigenes Thema per E-Mail mit der Lehrperson absprechen, die über die Eignung entscheidet.
- **Report**: 8 Seiten zum gewählten Thema mit Overleaf-Template und 1–5 zitierbaren Quellen (kein Wikipedia), Abgabe bis 28.02.2027 (soft deadline mit Abzug).
- **Poster Session** mit final minitest am 15.1.2027 um 11:45 (Moodle; F2 nennt 16.1.), Anwesenheit Pflicht, sonst 25-Minuten-Ersatzpräsentation in einem verwandten Kurs.
- **Poster-Druck**: PDF (300 dpi, A2 oder A1) bis 9.1. schicken, dann druckt die Lehrperson über die Kopierzentrale.

3 Gut zu wissen

Details aus den Bildfolien F39–40,47

- **PRISM-Zeitleiste**: Microsoft zuerst (9/11/07), Apple zuletzt (Oct 2012), Kosten ca. $20M pro Jahr.
- **PRISM-Daten**: E-Mail, Chat (Video, Voice), Videos, Photos, Stored Data, VoIP, File Transfers, Video Conferencing, Notifications of target activity und Social-Networking-Details.
- **XKEYSCORE (2008)**: ca. 150 Sites mit über 700 Servern weltweit.

Bewertung: Angaben widersprechen sich F3; P7–8; T0:00–0:28; M

- **Punkte**: Aktuell (F3, Transkript) Minitests bzw. Final Exam 45, Report 25, Poster/Presentation 30, die ältere Moodle-Seite nennt noch 45/45/10.
- **Bestehen**: Moodle verlangt mindestens 20 Punkte auf Minitests oder Final Exam (P8: 22) und insgesamt mindestens 50 Punkte.
- **Notenschlüssel**: 0–49,9 = 5, 50–54,9 = 4, 55–74,9 = 3, 75–84,9 = 2, 85–100 = 1.

4 Selbsttest – zehn Fragen im Stil von F77–F83

1. What is Security Engineering?
Systeme bauen, die trotz **malice, error and mischance** dependable bleiben (design, implement, test, adapt); ohne Threat Actor wäre es Safety.

2. Describe the four key steps in Security Engineering Basics.
Threat Model → Security Policy → Implementation → Assurance: Gegner bestimmen, Schutzziele festlegen, Mechanismen umsetzen, Erfolg auch Dritten beweisen.

3. Define subject, principal and person.
Person: physical oder legal person; **Subject**: physical person in irgendeiner Rolle; **Principal**: authentifizierbare, im Security System handelnde Entität, auch Gerät, Role, Channel oder Compound.

4. What is the difference between trust and trustworthiness?
Trusted: Versagen kann die Security Policy brechen (z. B. TPM); **trustworthy**: versagt nicht (Gegenbeispiel: Key Material verkaufender NSA-Mitarbeiter).

5. What is the difference between confidentiality and privacy?
Confidentiality: Pflicht, fremde Geheimnisse zu schützen (Nutzen der Organisation); **Privacy**: Recht/Fähigkeit, eigene Daten und Raum zu schützen (Nutzen des Individuums).

6. Explain integrity and authenticity.
Integrity: Daten wurden nicht verändert (at move/rest); **Authenticity**: **Integrity + Freshness + Proof of Identity**, also ein genuine Principal und kein Replay.

7. What is a weakness / vulnerability / exploit? CVE/CWE?
Weakness: kann zu Vulnerabilities beitragen (CWE-125); **Vulnerability**: führt mit einer Threat zum Security Failure (CVE-2014-0160 Heartbleed); **Exploit**: Methode/Code zur Ausnutzung.

8. How does a security target differ from a security policy? What is a protection profile?
Policy = what (Business Goals); **Target** = how (Spezifikation für ein Produkt); **Protection Profile** = device-independent Interface dazwischen für vergleichende Evaluations.

9. What is PRISM, and how does it differ from TEMPORA and XKEYSCORE?
PRISM: Serverzugriff bei großen Providern (downstream collection, „get the server"); **TEMPORA**: Glasfaser-Abgriff (upstream collection); **XKEYSCORE**: verteilte Search Engine über die gesammelten Daten.

10. What is Stuxnet? How did it work?
Worm von **USA & Israel** gegen Irans Zentrifugen (2008–09): USB-Infektion, Suche nach Siemens-Steuerung, Zero-Days übernehmen die PLCs, Zentrifugen drehen bis zum Versagen, falsches Feedback tarnt es; erste APT gegen cyber-physische Infrastruktur.